

TianShanOS

安全页面完整操作指南

操作步骤、结果确认与安全提醒

对应版本：TianShanOS 0.6.1

本指南依据 TianShanOS 0.6.1 的功能与界面编写。升级到后续版本后，未发生变化的功能仍可参照本指南；版本号不同并不意味着本指南全部失效。若界面、操作步骤或结果提示发生变化，请结合当前版本说明确认后再操作。

修订日期：2026-10-09

目录

1. 开始前先确认	3
2. 修改设备登录密码	4
3. 用 SSH 密钥连接服务器	5
4. 管理密钥、主机与指纹	7
5. 配置 HTTPS 证书与 mTLS	9
6. 使用 Config Pack 前先看限制	11
7. 故障与安全事件处理	12
8. 版本说明与常用术语	13

这份指南帮助你修改设备密码、建立 SSH 连接、核对服务器身份，并管理设备证书。首次使用建议按第 1、2、3 章操作；证书与配置包由负责这些功能的管理人员处理。

使用前请确认管理网络可信。当前完整管理页面使用 HTTP，多数接口尚未统一执行登录和权限检查。请将设备放在受控的管理网络中；安装 HTTPS 证书不会把完整管理页面自动切换到 HTTPS。

1. 开始前先确认

1.1 找到你需要的功能

你要做什么	到哪里操作
修改设备 root/admin 密码	账号安全，见第 2 章
让设备用密钥连接服务器	密钥管理、已部署主机，见第 3 章
复制密钥、核对服务器身份	密钥管理、已知主机指纹，见第 4 章
配置设备证书和双向证书认证	HTTPS 证书，见第 5 章
交换加密配置包	配置包，见第 6 章；通用配置应用尚未完成

1.2 账号与设备身份

- admin 能进入安全页，看到密钥、主机、证书和配置包功能，但看不到“账号安全”。
- root 还能设置 root/admin 密码，或重置 admin 密码。密码管理操作会核验 root 身份。
- Developer 设备 由设备证书中的组织单位（OU）属性识别，是设备身份。当前只有这类设备能导出配置包和 SSH 主机配置；以 root 登录不会改变设备身份。

页面能否显示某个按钮，不等于对应接口已完成权限控制。除密码管理等自行校验身份的操作外，当前仍需依靠可信管理网络限制访问。

1.3 操作前的准备

- 确认浏览器地址栏中的 IP 对应目标设备，电脑也在可信管理网络中。
- 向服务器管理员确认 SSH 地址、端口和用户名。
- 页面部署或撤销公钥需要远端账户密码，且账户允许密码登录。是否继续允许密码登录，由服务器管理员决定。
- 撤销授权、删除密钥或更换证书前，确认还有服务器控制台、另一管理员密钥或设备 HTTP 管理入口可用。

2. 修改设备登录密码

这里修改的是 TianShanOS 登录密码，不会修改远端服务器的 SSH 密码。

2.1 首次登录的密码提醒

账号尚未标记为已修改密码时，登录后会出现改密提醒。请设置独有的长密码。选择“稍后修改”会关闭提醒，不会替你完成改密。

这个提醒不是随时可打开的账号设置入口。admin 已改过密码后如需再次改密，可由 root 在安全页设置。

2.2 由 root 设置密码

1. 以 root 登录，打开导航中的“安全”。
2. 在“账号安全”找到 root 或 admin 密码管理，填写新密码和确认密码。
3. 点击“设置 root 新密码”或“设置 admin 新密码”。界面接受 4-64 个字符；4 个字符只是技术下限，请使用独有的长密码。

确认结果：用无痕窗口重新登录，确认新密码可用，再退出原会话。设置新密码不会自动结束已有会话。

登录失败时：先核对账号和设备地址。连续 5 次失败会锁定约 5 分钟，不要反复猜测。

2.3 重置 admin 密码

root 可点击“重置 admin 为默认密码”，将 admin 密码恢复为 `rm01`，并清除登录锁定。重置后，立即用新会话登录 admin 并设置独有密码。

默认密码仅用于临时恢复访问。完成恢复后及时改密，并退出不再需要的旧会话。

3. 用 SSH 密钥连接服务器

首次设置按“生成 RSA 密钥 → 部署公钥 → 检查结果 → 测试连接”进行，并核对服务器指纹。退役时先撤销各服务器上的授权，确认旧密钥不能登录，最后删除设备中的密钥。

3.1 生成密钥

- 1. 在“密钥管理”点击“生成新密钥”。
- 2. 输入未使用的密钥 ID，例如 `backup01`。建议使用不超过 10 个字符的英文、数字组合，不要包含逗号。中文会占用多个字节，不能按 10 个汉字计算。
- 3. 选择 RSA 2048 或 RSA 4096。默认是 RSA 2048；页面也列出 ECDSA，但当前 SSH 流程不支持它，请为 SSH 选择 RSA。
- 4. 按需填写备注和别名。只有需要备份或迁移私钥时，才打开“可导出”开关；生成后没有修改该选项的页面入口。
- 5. 按需设置“隐藏”，然后点击“生成”。隐藏仅用于列表显示，不能作为真实 ID 的保密措施。

确认结果：完成后窗口会关闭并刷新列表。找到正确的 ID 和 RSA 类型，点击“公钥”，确认完整文本以 `ssh-rsa` 开头。

等待过程中：不要重复提交。关闭窗口不会取消设备上的生成操作。

你看到的提示	下一步
ID 已被使用	换一个未使用的 ID；新版新建流程不会覆盖已有密钥
已达到数量上限	SSH 密钥容量为 8 个，先按撤销流程清理不用的密钥
存储空间或内存不足	先处理设备资源问题，再尝试；不要把失败当成已生成
密钥已生成，但列表刷新失败	手动刷新列表核对，无需重新生成
尚未确认生成结果	设备可能仍在处理，先等待并核对记录，不要重复生成同一 ID
数据清理未完成	先检查设备存储状态，必要时请管理员处理，暂停继续生成

查到同 ID 的记录，只能说明记录存在。结果未确认时，还需要核对它是否对应预期密钥，不能据此断定本次生成完整成功。

3.2 部署公钥

部署会把公钥追加到远端账户的 `~/.ssh/authorized_keys`，使该账户可以接受对应私钥登录。服务器密码不会因此改变。

- 1. 在目标密钥行点击“部署”。
- 2. 填写服务器地址、用户名、SSH 端口和“SSH 登录密码”。

- 3. 核对地址与账户，点击“开始部署”。
- 4. 阅读结果提示，并在“已部署主机”检查对应记录。

新版在使用密码认证前检查主机指纹，已知主机的指纹变化会被拒绝。但首次部署到新主机时仍会自动保存并信任其指纹，页面不会先要求人工核对。因此首次部署仍应在受控网络中进行，并通过可信渠道核对完整指纹。

3.3 分清部署结果

结果提示的含义	你应该做什么
公钥已部署、主机已登记、公钥登录已验证	检查主机信息，再测试实际需要执行的任务
公钥已部署、主机已登记，但公钥登录未确认	点击“测试”；失败时从另一管理入口核对远端授权和账户设置
公钥已部署，但主机登记失败或未确认	先检查主机列表和远端授权，不要直接重复部署
部署完成，但列表刷新失败	手动刷新；列表刷新失败不表示远端公钥没有写入

不要因结果不完整而反复部署：每次部署都会追加公钥，可能产生重复行。需要确认远端结果时，请用另一管理入口查看 `authorized_keys`。

3.4 测试连接

- 1. 在“已部署主机”核对地址、端口、用户名和密钥 ID，点击“测试”。
- 2. 如果出现“主机指纹”确认窗口，先按第 4.3 节取得可信指纹并核对，再决定是否点击“信任并连接”。
- 3. 连接后，设备尝试执行固定回显命令 `echo "TianshanOS SSH Test OK"`。

如何理解成功提示：当前测试页面检查的是请求成功，仍未检查远端命令的退出码和回显内容。它可用于基础连接检查；重要任务还需实际检查输出、退出状态和权限。测试成功也不证明 `sudo` 或其他业务命令可用。

失败时：检查网络、SSH 服务、账户和远端公钥授权。涉及指纹变化或身份不明时，停止重试，先核对服务器身份。

3.5 撤销远端授权，再删除本地密钥

- 1. 确认另一条服务器管理入口可用，原密钥仍在设备上。
- 2. 在对应主机行点击“撤销”，输入服务器密码，确认“撤销并移除”。也可从密钥行发起撤销并填写目标信息。

- 3. 阅读结果，再从可信入口检查远端 `authorized_keys`，确认对应公钥及重复行已移除，并验证旧密钥不能登录。
- 4. 撤销会留下 `authorized_keys.bak`。按服务器备份策略处理，避免以后恢复旧授权。
- 5. 检查本地主机记录是否已移除。新版会检查移除请求；如果远端已撤销但本地移除失败，刷新核对记录后再处理本地清理。
- 6. 所有目标服务器都完成撤销后，才删除设备中的旧密钥和不需要的私钥副本。

提示未找到公钥：先确认账户正确且远端确实没有该公钥，再选择仅移除本地记录。

主机无法移除：记录可能正被服务使用或保护。请在“指令”或相关自动化设置中核对服务状态和引用，完成停止或引用处理后再试。状态不明时请管理员核实。

撤销提示失败：核对失败发生在哪一步。公钥可能已经从远端删除，只是本地记录清理失败；以服务器上的授权和实际登录检查为准。不要先删除本地密钥。

4. 管理密钥、主机与指纹

4.1 复制公钥与导出私钥

公钥：点击密钥行的“公钥”，复制完整的一行给服务器管理员。公钥是公开材料，发错对象本身不会泄露私钥。管理员将它加入授权列表后，才会产生对应访问权限。

私钥：只有生成时打开“可导出”的密钥才能导出。请在可信电脑和隔离管理网络中点击“私钥”，保存到受控密钥库，并清理剪贴板和下载目录中的临时副本。不要粘贴到聊天、工单或日志里。

复制按钮无响应：HTTP 页面可能受浏览器剪贴板限制。可手动选中并复制文本，再检查首尾标记和内容是否完整。不要为方便复制而放宽浏览器安全设置。

4.2 分清撤销、移除和删除

操作	实际改变什么
撤销公钥	尝试删除服务器授权，需要远端密码
移除主机	删除设备本地连接记录，不撤销服务器授权
删除密钥	删除设备本地密钥，不会访问服务器或撤销授权
移除已知主机指纹	删除设备保存的服务器身份记录，不删除连接记录或远端授权

“已部署主机”是本地清单，不会持续查询服务器。列表为空不代表远端授权已清理，有记录也不保证现在能登录。

4.3 核对 SSH 服务器指纹

指纹用于确认你连接的是哪台服务器。页面保存 SHA-256 摘要的 64 位十六进制值；常见 OpenSSH 工具显示 `SHA256:base64`。请管理员提供相同格式的值，不能直接比较这两种字符串。

首次部署后：在“已知主机指纹”点击“查看”，与服务器控制台、资产系统或另一条可信渠道提供的完整值比较。表格仅显示前 32 位，不足以完成核对。

测试时出现确认窗口：窗口显示当前完整指纹。通过可信渠道核对一致后，才选择“信任并连接”。指纹变化时，同时核对服务器身份、IP、端口和维护记录，不要只因为弹窗出现就确认。

指纹不一致或来源不明：取消连接并调查。若此前已在不可信连接中使用过密码，按可能泄露处理，从可信入口修改密码、检查登录日志和清理不应存在的授权。不要通过可疑连接发送密码来执行撤销。

服务器正常重装或换钥：先核对新的完整指纹和变更记录。核实后可在测试确认窗口接受新指纹；也可移除旧指纹，再重新测试并核对确认。测试入口会要求明确确认，不能沿用旧指南中“重连就自动信任”的做法。

保管 SD 卡：已知主机指纹会同步成 SD 卡明文 JSON。启动时有 SD 指纹配置就会以它为准替换对应本地记录；文件没有签名保护，不要允许不可信人员修改。

4.4 导入与导出 SSH 主机配置

这是专用的 `.tscfg` 流程。包中保存地址、端口、用户、认证类型和密钥 ID，不包含 SSH 密码或私钥，也不会授予远端权限。它与第 6 章尚未完成的通用配置应用不同。

导出：在 Developer 设备点击主机行“导出”。给另一设备使用时，填写并核对目标设备证书，生成后点击下载，并确认文件已保存。普通设备即使看到按钮，后端也会拒绝导出。

导入：

1. 确认包为本设备制作，SD 卡可写，来源已通过可信渠道核对。
2. 确认本设备有包所引用的正确密钥。同 ID 不够，密钥本身必须与服务器授权对应。
3. 点击“导入主机”，选择文件并查看预览。只有确实要替换同名配置时，才启用覆盖。
4. 确认导入后按提示重启。导入先保存包到 SD 卡，重启时才尝试加载和解密。
5. 等待启动加载完成，刷新主机列表，核对地址、用户、端口和密钥，再测试连接。

预览通过不证明签名者可信，也不证明包属于本设备；目标指纹检查到加载时才执行。新版启动会合并主机配置，并保留其他本地记录，不要预期导入一个包后旧列表会全部清空。

错误记录应移除，并核对 SD 卡中对应配置已清理。若仍有旧包，可能在重启后再次加载；已有服务使用该记录时，先处理服务引用。更换设备证书前也请阅读第 5.6 节。

5. 配置 HTTPS 证书与 mTLS

当前 443 服务提供健康、身份和权限测试接口，不承载完整管理页面。默认启动需要设备私钥、设备证书、客户端 CA 链和正确设备时间。

5.1 先分清证书方向

- 设备证书和私钥 让设备向客户端证明身份。
- 客户端证书和私钥 由电脑或服务持有，让客户端向设备证明身份。
- 设备上的客户端验证 CA 用于验证客户端证书，不会自动让电脑或浏览器信任设备证书。

双方都出示证书的方式叫 mTLS。客户端仍需信任设备证书的签发 CA，并检查访问名称、用途和有效期。

5.2 读懂证书状态，先校准时间

“已保存” “在有效期内” “HTTPS 运行中” 分别说明凭证存储、时间有效性和服务状态，不能相互替代。

页面状态	下一步
未安装设备证书、缺少私钥或客户端验证 CA	按后续步骤补齐对应凭证
有效期：待校时确认	先确认电脑时间正确，再点击“用当前电脑时间校时（来源：浏览器）”
有效期：尚未生效或已过期	核对设备时间和证书日期；确实过期时安排续签
有效期内，但 HTTPS 未运行	查看页面列出的缺少材料、密钥不匹配或启动错误，处理后刷新检查
运行中的服务仍使用旧材料	保存其他工作后重启设备，确认新凭证满足启动条件并被使用
存储结果不确定或状态读取失败	先刷新核对；按提示重启检查，不要反复安装或删除

校时后再检查设备时间和同步状态。服务尚未运行时，系统会在凭证与时间条件满足后尝试启动；如果仍未运行，以页面原因排查，不要单凭安装成功认为服务可用。

5.3 生成设备私钥与证书申请

1. 点击“生成密钥对”。这会生成独立的 ECDSA P-256 私钥，与 SSH 密钥无关，不能从此界面导出。
2. 已有私钥时先阅读第 5.6 节。继续生成会覆盖它。
3. 点击“生成 CSR”，填写设备 ID (CN)、 “组织” 和 “部门”，或全部留空。部门对应证书组织单位 (OU)。

4. 点击“生成证书签名请求”，复制完整 CSR 文本给 CA 管理员。

填写建议：设备 ID 使用简短、稳定的英文和数字。页面限制为 63 个 UTF-8 字节，中文不能按 63 个汉字计算；字段过长时按提示缩短。

签发前核对名称：自定义字段路径不生成 SAN；全部留空时，CN 固定为

`TIANSHAN-DEVICE-001`，仅在取得当前 IP 时加入该 IP 的 SAN，不含 DNS SAN。请 CA 管理员通过受控签发流程把实际访问的 IP/DNS 加入最终证书，确认所需认证用途。此表单不能编辑 SAN。

CSR 是申请文本，不含私钥，也不会自动安装证书。生成后让 CA 管理员解析并核对公钥、主体和 SAN。

5.4 安装设备证书

1. 取得与当前设备私钥匹配的 PEM 证书。
2. 点击“安装证书”，粘贴带首尾标记的完整文本，再点击“安装”。
3. 检查“已保存”提示、证书有效期和 HTTPS 实际状态。查看主体、签发者和日期是否正确。

安装会检查格式和公私钥匹配。新版另行展示时间有效性和启动条件，但这仍不能替代客户端对证书信任链、访问地址和用途的验证。

密钥不匹配时，先找回当前 CSR 对应的证书。不要为了消除错误而重新生成私钥。结果未确认时，刷新核对保存状态再决定是否重试。

5.5 安装客户端 CA 链并测试

1. 点击“安装 CA”，粘贴信任客户端证书所需的一个或多个 PEM CA 证书，再点击“安装”。
2. 查看状态。服务尚未运行时，材料和时间齐备后会尝试启动；已经运行且材料改变时，按页面提示重启设备应用。
3. 用受信任、用途和角色正确的客户端证书访问对应测试接口。
4. 再用不受信任的证书或不提供证书测试，确认连接被拒绝。

确认结果：HTTPS 显示运行中，并使用预期证书；页面显示“活动证书 SHA-256”时可核对其指纹。可信客户端只能访问其角色允许的接口，不可信客户端不能接入。这些连接结果仍需在实际设备上验证。

5.6 更新证书或删除全部凭证

证书到期：可沿用未泄露的私钥申请新证书，安装后按页面状态应用并重新测试。配置包绑定接收方证书指纹；即使沿用同一私钥，换证书后重新初始化或重启加载的旧包也可能因目标不匹配被拒绝。更换前安排替代包。

替换私钥：旧 CSR 和证书不再对应新私钥。这不会自动完成 CA 吊销；旧私钥泄露时需与 CA 管理员另行处理。失去旧私钥后，依赖它的旧包可能无法恢复。

删除全部凭证：点击“删除凭证”会一起删除设备私钥、设备证书和客户端 CA 链。先确认 HTTP 管理入口可用，并处理需要保留的配置包。公开证书备份不能恢复私钥。

删除后应显示“未安装设备证书”，并检查材料是否缺失。正在运行的 HTTPS 服务可能仍持有旧凭证，删除存储不等于在线吊销；按状态提示重启，再确认不再使用旧凭证。恢复时重新生成密钥、签发设备证书、安装 CA 链并测试。

6. 使用 Config Pack 前先看限制

Config Pack 是加密、签名的 `.tscfg` 配置包。当前可生成和检查包，但通用配置应用尚未完成，不应承担生产批量配置、灾难恢复或配置生效验收。

6.1 各按钮实际做什么

操作	当前结果
导出设备证书	提供公开证书，供发送方为本设备制作包，不导出私钥
仅验证	检查结构和自带证书对应的密文签名，不确认签名者可信或接收方匹配
安全页选择或粘贴包后导入	前后端参数仍不匹配，当前不能完成这一流程
配置包列表中的导入	验证设备上已有文件，不复制、不解密、不应用
应用	解密并列出模块名，没有写入模块配置，仍可能提示成功
Developer 导出配置包	生成可下载的包，并尝试保存到 SD 卡

6.2 核对来源与目标

目前验证使用包内自带的签名者证书，没有完成其证书链信任检查。签名保护的是密文，不能据此认为所有显示信息都已获得可信认证。“官方”标记也不是来源证明。

通过资产系统或独立可信渠道核对签名者证书指纹、目标设备证书和包的用途。预览中的目标名称不能代替证书指纹核对；在同一条消息中同时收到证书和指纹，也不算独立核验。

6.3 提供设备证书与检查收到的包

提供本设备证书：点击“导出设备证书”，复制完整 PEM 和显示的指纹。把公开证书交给发送方，再通过另一可信渠道核对指纹。

检查收到的包：打开“导入配置包”，选择或粘贴 `.tscfg`，点击“仅验证”。检查签名者信息并核对来源。验证不会应用配置，也不证明包属于本设备；来源、目标或用途不清时停止。

验证通过后，也不能依赖当前通用“导入”和“应用”完成配置。请在对应功能页面使用已支持的设置方式，再检查实际结果。

6.4 Developer 设备导出配置包

- 1. 准备 SD 卡上的有效 JSON 配置文件，取得已核对的目标设备证书。
- 2. 点击“导出配置包”，选择文件，填写名称和说明，粘贴接收方设备证书。
- 3. 生成后点击“下载”，确认浏览器已保存 .tscfg。
- 4. 分别检查下载文件和设备 /sdcard/output_config/ 中的保存结果。SD 写入失败时，包内容仍可能可供下载。

导出不修改源配置。目标错误或接收方证书更换后，需要重新制作包。导出成功也不能证明接收端的通用应用流程已经可用。

7. 故障与安全事件处理

7.1 常见问题

现象	处理方式
看不到账号安全	该区块仅对 root 显示
ID 已被使用或过长	选择短且未使用的 ID，见第 3.1 节
生成结果未确认	等待并核对记录，不重复提交同一 ID
部署成功但记录缺失或测试失败	分别核对远端授权、本地记录和登录能力，见第 3.3 节
主机指纹确认或变化	先从可信渠道核对，再决定是否信任，见第 4.3 节
撤销后本地记录仍在	核对远端授权；再处理本地移除失败和服务引用
移除主机后仍能登录	移除只清理本地记录，需另行撤销远端公钥
证书已保存但 HTTPS 未运行	先检查设备时间，再处理页面列出的材料或启动问题
新证书尚未用于运行中的服务	按页面提示重启应用，再核对活动证书
客户端拒绝证书	核对客户端信任库、访问名称、用途和有效期
配置包应用成功但设置没变	当前通用应用未写入模块配置，回到各功能页面设置

7.2 私钥或密码可能泄露

- 1. 限制设备和相关资料的访问，保留必要的调查记录。
- 2. SSH 私钥泄露时，通过可信入口逐台撤销对应公钥，检查备份，确认旧密钥不能登录。
- 3. 用新 ID 生成 RSA 密钥并重新部署，验证后删除旧密钥和导出副本。
- 4. SSH 密码泄露时，从可信管理入口修改远端密码并核对登录记录。

5. HTTPS 私钥泄露时，按第 5.6 节替换凭证，与 CA 管理员处理吊销及旧配置包。

本地主机列表可能没有覆盖所有曾授权的服务器，清理时应结合服务器和资产记录。分享日志前检查是否包含人为写入的密码、密钥或其他敏感信息。

7.3 当前版本的使用边界

HTTP 管理、接口鉴权、首次部署自动信任和 Config Pack 限制仍需纳入使用判断。“隐藏”开关不构成访问控制。

本次检查的构建配置未启用 NVS Encryption、Flash Encryption 和 Secure Boot，不能据此宣称私钥已获得加密存储和安全启动保护。实际设备的烧录配置和硬件安全设置需另行核验。场景无法接受这些限制时，请由安全负责人安排隔离或修复。

8. 版本说明与常用术语

8.1 本版指南的适用范围

本指南依据 TianShanOS 0.6.1 的代码和中英文界面编写，核查日期为 2026-10-09。后续版本中未改变的功能仍可参照；若按钮、步骤或提示不同，先查看当前版本说明，再确认操作。

本次核查包含代码与本机模拟界面，未把模拟结果作为实际设备的连接验收。SSH 登录、TLS 握手、服务重启和远端授权需按本指南在实际环境中确认。

8.2 常用术语

- 公钥 / 私钥：公钥交给授权方，私钥保密；登录时使用匹配的一对密钥。
- 指纹：用于核对服务器或证书身份的摘要。不同显示格式需先统一再比较。
- CSR / CA：证书申请，以及签发或验证证书的机构或相应证书。
- CN / O / OU：证书主体中的通用名、组织、组织单位。页面“部门”对应 OU。
- SAN / EKU：证书覆盖的访问名称或 IP，以及允许的认证用途。
- PEM：带 BEGIN/END 标记的文本格式，可用于证书、CSR 和密钥。
- mTLS / PKI：双方都出示证书的连接方式，以及证书与信任管理体系。
- NVS：设备 Flash 中保存设置与密钥的区域；名称本身不表示数据已加密。